



TRƯỜNG ĐẠI HỌC  
BÁCH KHOA HÀ NỘI  
HANOI UNIVERSITY  
OF SCIENCE AND TECHNOLOGY

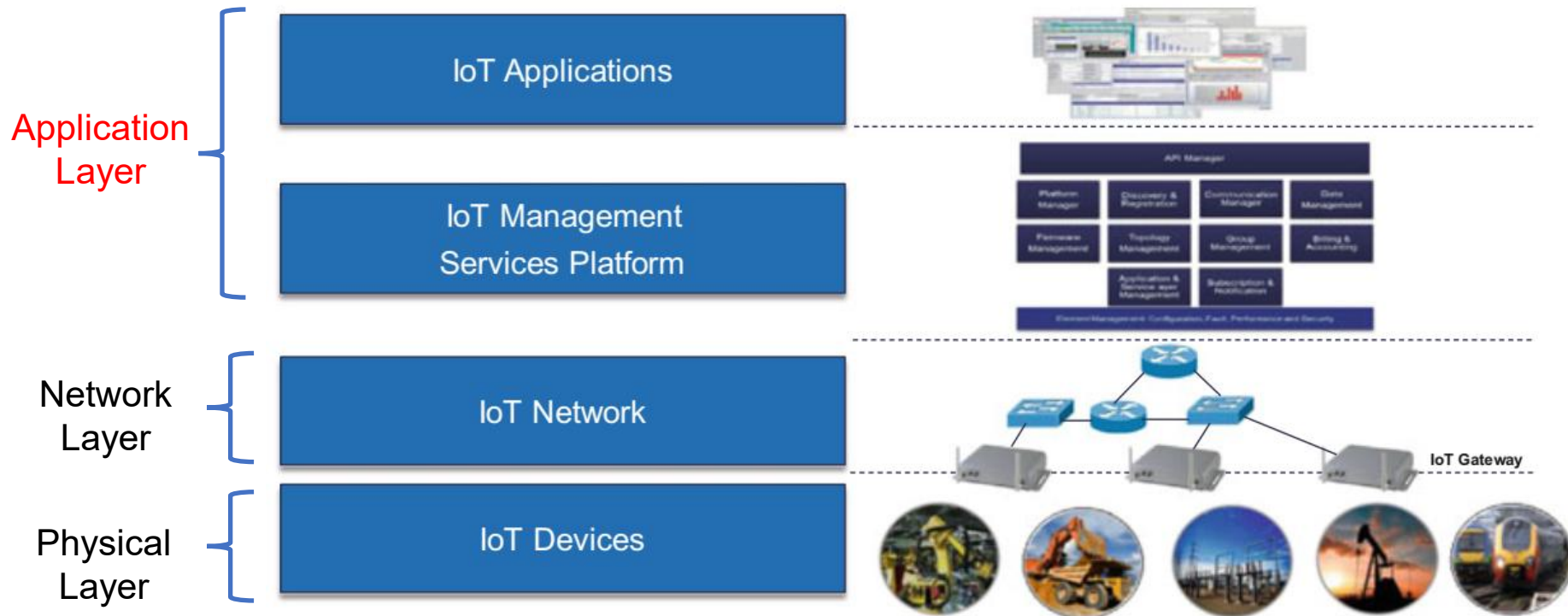
# CHƯƠNG 7

## BẢO MẬT TẦNG ỨNG DỤNG

ONE LOVE. ONE FUTURE.

- 1. Giới thiệu
  - 1.1. Hiện trạng về an toàn thông tin
  - 1.2. OWASP
- 2. Ứng dụng Web
- 3. Lỗ hổng Web
- 4. Giải pháp tìm kiếm lỗ hổng Web

# IoT Stack





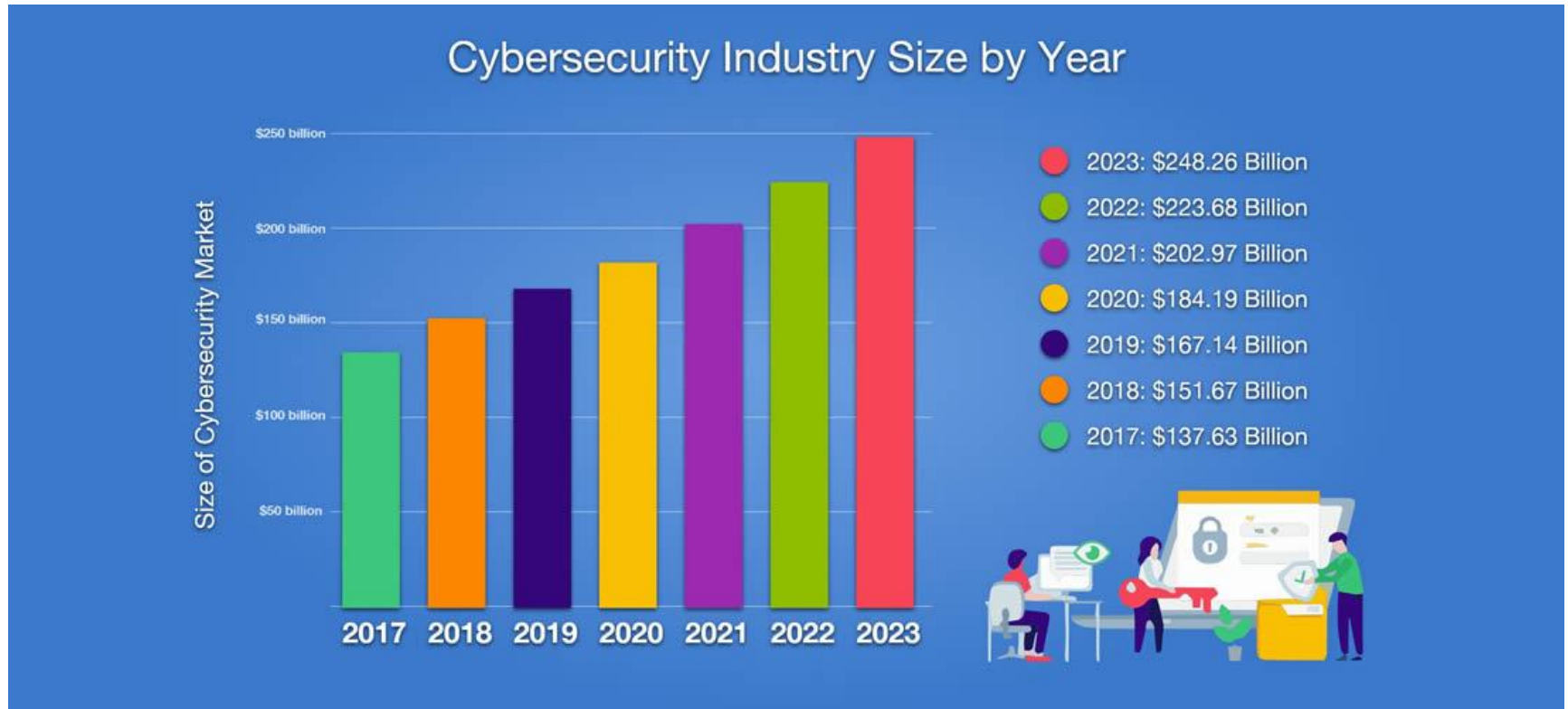
**TRƯỜNG ĐẠI HỌC  
BÁCH KHOA HÀ NỘI**  
HANOI UNIVERSITY  
OF SCIENCE AND TECHNOLOGY

# 1. Giới thiệu

ONE LOVE. ONE FUTURE.

# 1.1. Hiện trạng về an toàn thông tin

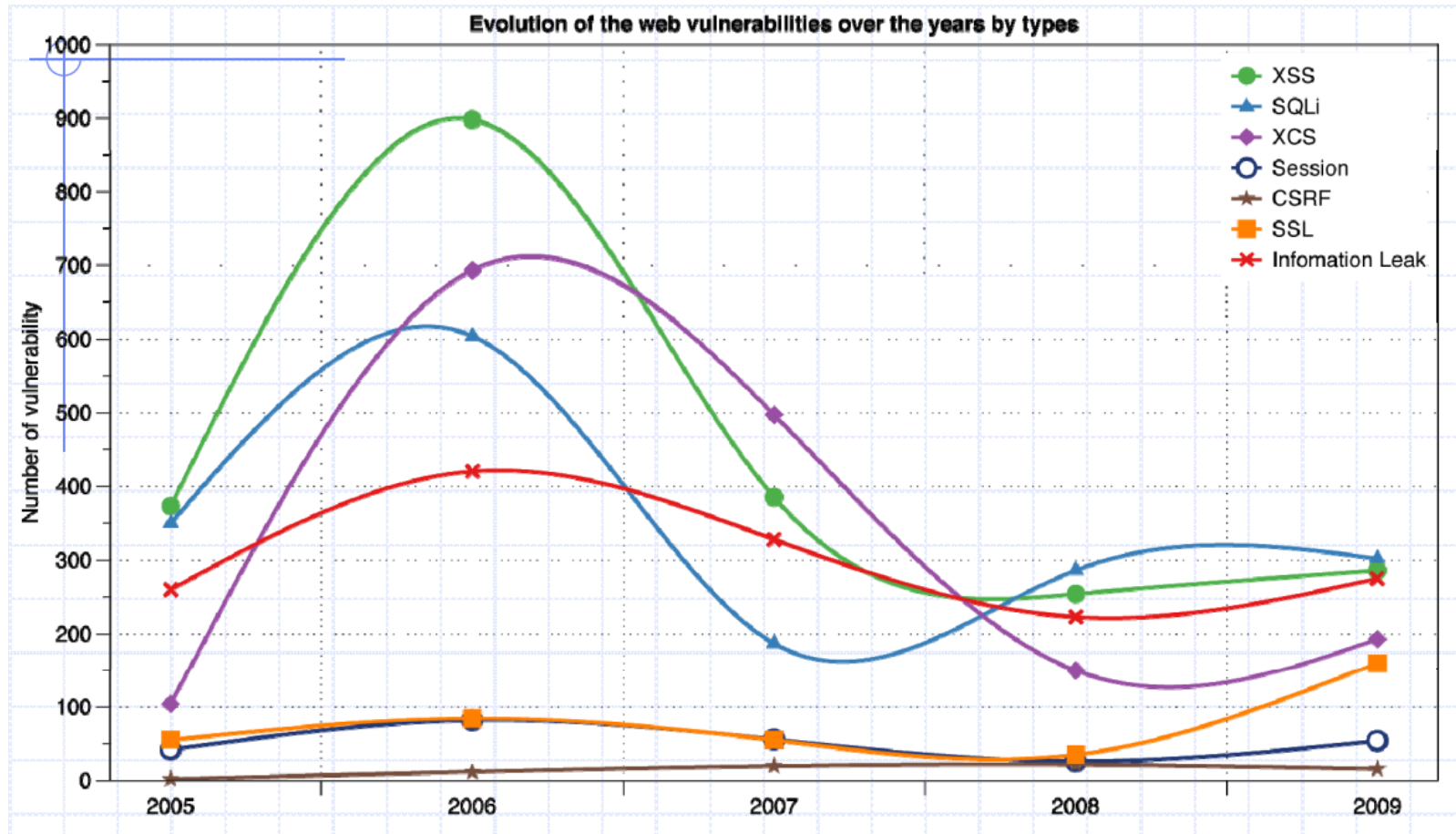
- Thị trường về an toàn thông tin



IBM, Global Website Hacking Statistics 2020, <https://community.ibm.com/community/user/security/blogs/lissa-coffeeey1/2020/11/30/global-website-hacking-statistics-in-2020>

# 1.1. Hiện trạng về an toàn thông tin

## • Thống kê về lỗ hổng Web



John Mitchell, Web Application Security. CS 155. Spring 2014, <https://crypto.stanford.edu/cs155old/cs155-spring14/lectures/09-web-site-sec.pdf>

## 1.2. OWASP

- OWASP (Open Web Application Security Project)
- Cộng đồng online cung cấp các tài liệu, phương pháp và công cụ liên quan đến bảo mật web.
- Lịch sử:
  - 09/2001: Mark Curphey
  - 2003 - 09/2011: Jeff Williams
  - 2015: Matt Konda
- OWASP Top 10 – 2021 là kết quả nghiên cứu của OWASP và hơn 40 đối tác.



**TRƯỜNG ĐẠI HỌC  
BÁCH KHOA HÀ NỘI**  
HANOI UNIVERSITY  
OF SCIENCE AND TECHNOLOGY

## 2. Ứng dụng Web

ONE LOVE. ONE FUTURE.



## 2.1. Web và ứng dụng Web

- Website

- Một hay nhiều trang chứa hình ảnh, âm thanh, văn bản, video, v.v. nhằm cung cấp thông tin cho người dùng. Ví dụ: Wikipedia, v.v.

- Ứng dụng Web

- Một web có chức năng và các yếu tố tương tác.
- Có khả năng tùy biến cao, thực hiện nhiều tác vụ và chức năng khác nhau. Ví dụ: Twitter, Facebook, v.v.

## 2.2. Đặc điểm của Web và ứng dụng Web

### • So sánh giữa Web và ứng dụng Web

| Đặc điểm   | Web                                                                                                                  | Ứng dụng Web                                                                                                               |
|------------|----------------------------------------------------------------------------------------------------------------------|----------------------------------------------------------------------------------------------------------------------------|
| Tương tác  | Cung cấp nội dung văn bản và hình ảnh mà người dùng có thể xem hoặc đọc.                                             | Không chỉ cho phép xem hoặc đọc mà còn cho phép tương tác với ứng dụng. Ví dụ: điền biểu mẫu, cung cấp dữ liệu, v.v.       |
| Xác thực   | <ul style="list-style-type: none"><li>- Không bắt buộc.</li><li>- Mọi người đều có thể truy cập công khai.</li></ul> | <ul style="list-style-type: none"><li>- Bắt buộc.</li><li>- Không đăng nhập thì không truy cập được vào dữ liệu.</li></ul> |
| Triển khai | Khi cập nhật nội dung, không yêu cầu biên dịch lại, chỉ cần cập nhật lại mã HTML.                                    | Khi cập nhật nội dung, cần biên dịch lại và triển khai lại ứng dụng.                                                       |



**TRƯỜNG ĐẠI HỌC  
BÁCH KHOA HÀ NỘI**  
HANOI UNIVERSITY  
OF SCIENCE AND TECHNOLOGY

# 3. Lỗ hổng Web

ONE LOVE. ONE FUTURE.

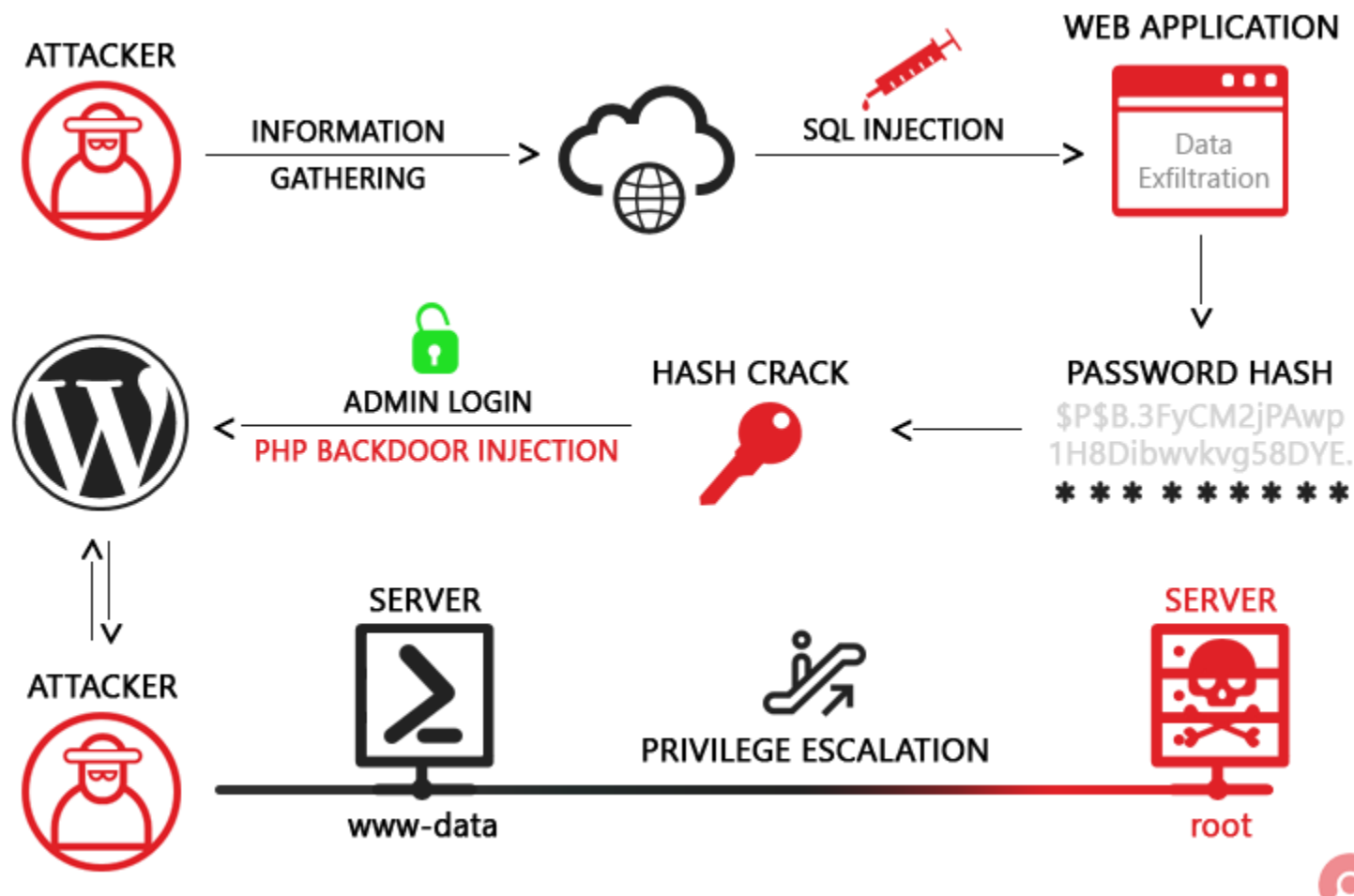
- Lỗ hổng Web
  - Injection
  - Broken Authentication
  - Security Misconfigurations
  - Cross Site Scripting (XSS)
  - Using Components with Known Vulnerabilities

## 3.1. Injection

- Lỗ hổng liên quan đến các câu truy vấn của ứng dụng.
- Kẻ tấn công chèn thêm một đoạn code để khai thác dữ liệu từ database, dữ liệu trên server (thông tin tài khoản, thẻ tín dụng. v.v).
- Cách kiểu injection:
  - SQL
  - LDAP (Lightweight Directory Access Protocol)
  - Xpath

# 3.1. Injection

- Cách thức khai thác



SQL injection, <https://topdev.vn/blog/sql-injection/>

# 3.1. Injection

- Ảnh hưởng:
  - Mất mát tài khoản cá nhân.
  - Lộ các dữ liệu bảo mật của hệ thống (thẻ tín dụng, số an sinh xã hội, v.v.).
  - Thay đổi dữ liệu của hệ thống (truy cập và tấn công nâng quyền, v.v.).
  - Hệ thống bị kiểm soát và truy cập trái phép (nâng quyền lên quyền root và truy cập, v.v.).

# 3.1. Injection

## ❑ Ví dụ về SQL injection

### • CardSystems

- Xử lý dữ liệu cho các giao dịch thanh toán quốc tế.
- SQL injection năm 2005.
- Hệ quả
  - Trên 40 triệu thẻ tín dụng đã bị lộ.
  - 2 hãng thẻ tín dụng (Visa USA Inc., American Express) dừng hợp đồng với CardSystems.

### • BKAV

- SQL injection vào 08/2021.
- Hệ quả:
  - Lộ mã nguồn sản phẩm của công ty (BKAV Pro, v.v.).

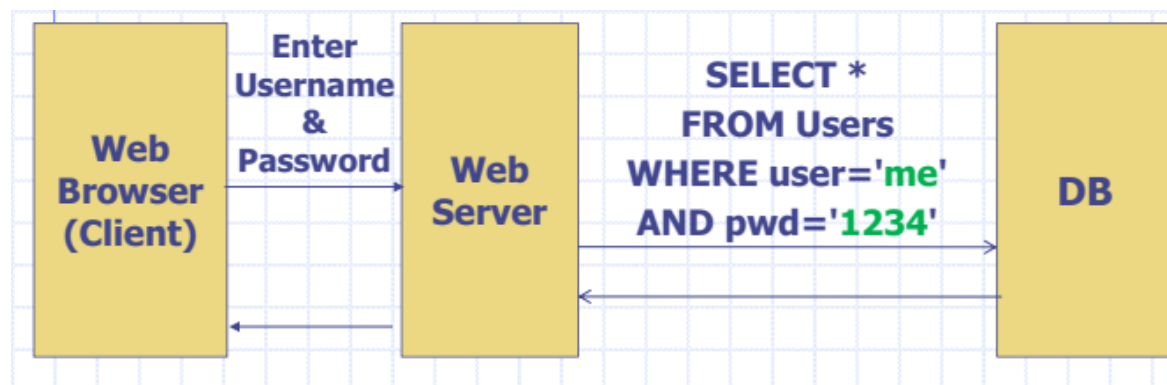


# 3.1. Injection

- Ví dụ: Trang đăng nhập (ASP)

```
set ok = execute( "SELECT * FROM Users  
    WHERE user=' ' & form("user") & " '  
    AND    pwd=' ' & form("pwd") & " ' " );  
  
if not ok.EOF  
    login success  
else fail;
```

- Truy vấn bình thường



## 3.1. Injection

- Truy vấn bất thường

- Người dùng truy cập trái phép: ' or 1=1 –

```
ok = execute( SELECT ...  
               WHERE user= ' ' or 1=1 -- ... )
```

- “--”: Bỏ qua các thông tin phía sau.

- Người dùng thay đổi cơ dữ liệu: ' ; DROP TABLE Users –

```
ok = execute( SELECT ...  
               WHERE user= ' ' ; DROP TABLE Users ... )
```

- Người dùng thêm tài khoản, reset mật khẩu, v.v.

## 3.2. Broken Authentication

- Sử dụng **tấn công từ điển** để truy cập trái phép.
- Sử dụng tập từ điển (100 triệu tài khoản, v.v.).
- Tồn tại do một số nguyên nhân:
  - Chính sách mật khẩu kém
  - Thay đổi/Quên mật khẩu, v.v.
- Giải pháp:
  - Tăng độ khó mật khẩu
  - Quản lí đăng nhập
  - Mã hóa mật khẩu trong database
  - Mã hóa trong quá trình đăng nhập
- Ví dụ: **Mirai** (9/2016), v.v.

## 3.3. Security Misconfigurations

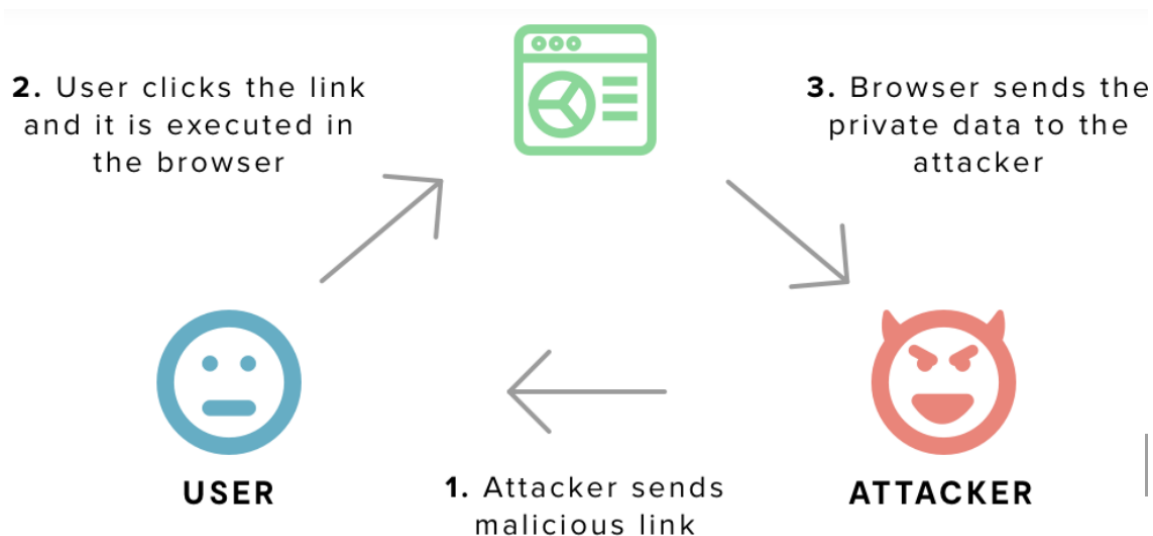
- Server hay các ứng dụng Web được cấu hình không đúng.
- Hệ quả
  - Lỗi trong quá trình phân quyền
  - Sử dụng tên đăng nhập và mật khẩu mặc định
- Giải pháp
  - Disable giao diện quản trị
  - Disable tài khoản mặc định
  - Cấu hình server để ngăn truy cập trái phép
  - Kiểm tra hệ thống để phát hiện các lỗi cấu hình không đúng.

## 3.4. Cross Site Scripting (XSS)

- XSS
  - Xảy ra khi kẻ tấn công **chèn mã độc vào các trang** sinh ra bởi ứng dụng Web.
- Các kiểu XSS
  - Reflected XSS
  - Stored XSS
  - DOM-based XSS

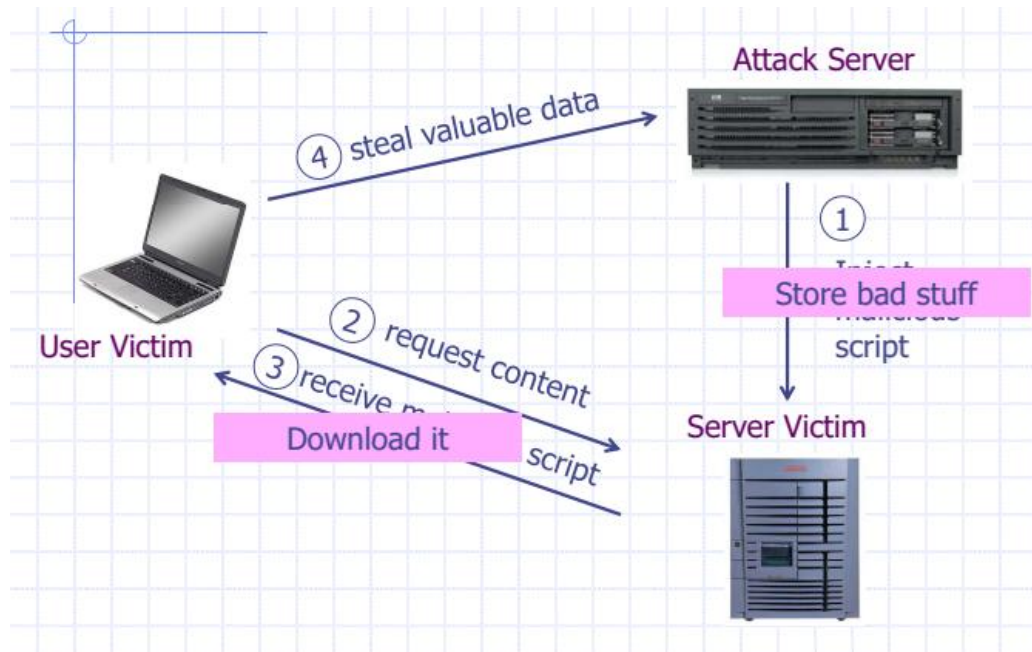
# Reflected XSS

- XSS phản chiếu: xảy ra khi tập lệnh độc hại được phản chiếu từ ứng dụng web tới trình duyệt của nạn nhân mà không lưu trữ lâu dài trên ứng dụng web.
- Cách khai thác
  - Email hoặc web chứa liên kết độc hại.



# Stored XSS

- XSS lưu trữ: kẻ tấn công **khai thác lỗ hổng** của các **ứng dụng Web** và **lưu code độc hại** trong database.
- Cách khai thác



# DOM-based XSS

- Khai thác XSS dựa vào việc thay đổi thay đổi cấu trúc DOM (Document Object Model).
- Mã nguồn ứng dụng web và phản hồi tới kẻ tấn công không thay đổi nên code độc hại không được lưu trữ trong phản hồi này.
- Code độc hại được lưu trữ trong môi trường trình duyệt của người dùng.



## 3.4. Cross Site Scripting

- Adobe Acrobat Reader Plugin dưới 7.0 tồn tại lỗ hổng XSS cho phép thực thi mã độc hại Javascript.

```
http://path/to/pdf/file.pdf#whatever_name_  
you_want=javascript:code_here
```

- Cách khai thác
  - Xác định vị trí của file PDF trên website (website.com).
  - Tạo ra URL khai thác lỗ hổng đó:  
[http://website.com/path/to/file.pdf#s=javascript:alert\("xss"\);](http://website.com/path/to/file.pdf#s=javascript:alert('xss');)
  - Dụ dỗ nạn nhân click vào link đó.
  - Khi máy nạn nhân sử dụng Adobe Acrobat Reader Plugin dưới 7.0 thì mã độc sẽ thực thi.

XSS in Adobe, <https://blog.jeremiahgrossman.com/2007/01/what-you-need-to-know-about-uxss-in.html>

## 3.4. Cross Site Scripting

- Cách khai thác tương tự đối với các máy tính của nạn nhân.

```
file:///C:/Program%20Files/Adobe/Acrobat%207.0/Resource/ENUtxt.pdf#blah=javascript:alert("XSS");
```

## 3.4. Cross Site Scripting

- Phòng tránh XSS theo OWASP
  - Đảm bảo rằng ứng dụng của bạn xác thực tất cả tiêu đề, cookie, truy vấn chuỗi, trường biểu mẫu và trường ẩn.
  - Triển khai các chính sách bảo mật xác định những nội dung được cho phép.

## 3.4. Cross Site Scripting

- Phòng tránh XSS
  - Lọc và xác thực dữ liệu đầu vào
    - Kiểm tra dữ liệu từ người dùng gửi lên
      - Chỉ cho phép những dữ liệu mong muốn
    - Loại bỏ những kí tự đặc biệt
      - Kí tự mã hóa, đặc biệt
      - Ví dụ: Mã hóa UTF-8.

## 3.4. Cross Site Scripting

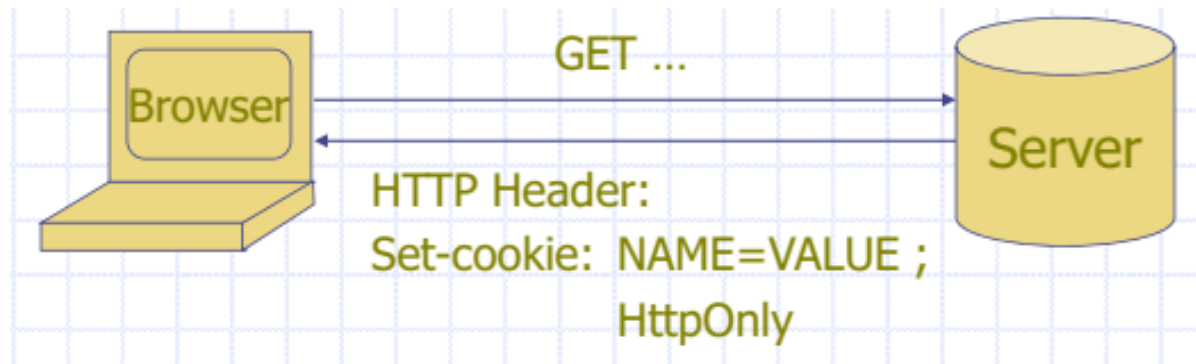
- Phòng tránh XSS

- Lọc đầu ra

- Lọc các kí tự HTML đặc biệt
      - &lt; for <, &gt; for >, &quot; for “
    - Chỉ cho phép các câu lệnh an toàn (chặn thẻ <script>, v.v.)
    - Chú ý các đoạn mã không nằm trong thẻ <script>

## 3.4. Cross Site Scripting

- Phòng tránh XSS
- HttpOnly Cookies



- Cookie được truyền qua HTTP(s) nhưng không truy cập được qua script.
    - Chặn việc đọc qua document.cookie
    - Chặn việc đọc qua XMLHttpRequest
- Ngăn chặn đánh cắp thông tin cookie qua XSS

## 3.5. Using Components with known Vulnerabilities

- Trong số các web bị tấn công năm 2017
  - 39.3% các web WordPress không được cập nhật.
  - 69.8% các web Joomla! không được cập nhật.
  - 65.3% các web Drupal không được cập nhật.
  - 80.3% các web Magento không được cập nhật.

## 3.5. Using Components with known Vulnerabilities

- Giải pháp ngăn chặn
  - Loại bỏ các thành phần, thư viện không cần thiết. v.v.
  - Liên tục giám sát các phiên bản phía người dùng và máy chủ.
  - Liên tục theo dõi các CVE để phát hiện lỗ hổng trong các thành phần của hệ thống.
  - Chỉ cài đặt các thành phần từ các nguồn an toàn.
  - Kiểm tra và xác thực các gói tin tải xuống.